

Relatório de Vulnerabilidades

INFORMAÇÃO CONFIDENCIAL

Camila Ferrete — camilaferrete.com.br

26 de maio de 2026

INTRODUÇÃO

Objetivo

Este relatório foi elaborado com o intuito de identificar, analisar e catalogar vulnerabilidades relacionadas ao domínio e à aplicação web da Camila Ferrete (camilaferrete.com.br), levando-se em conta a integridade, confidencialidade e disponibilidade das informações.

Foi feita a classificação e organização dos problemas encontrados, como também as possíveis abordagens iniciais para a resolução.

Metodologia

Foram usadas metodologias e recomendações de órgãos internacionais especializados em segurança da informação para a obtenção dos riscos envolvidos. Para a catalogação e verificação de riscos em Aplicações Web foi utilizado o padrão OWASP.

A intervenção foi feita segundo a metodologia Black Box, em que é simulada a abordagem de um atacante externo à aplicação.

Foram utilizados softwares especializados em reconhecimento e verificações manuais em todos os pontos críticos identificados no escopo.

SUMÁRIO EXECUTIVO

Visão Geral dos Testes de Segurança

TOTAL DE VULNERABILIDADES ÚNICAS	7
CRÍTICA	2
ALTA	0
MÉDIA	3
BAIXA	1
INFO	1
ZERO-DAY	0
EASILY-EXPLOITABLE	2

Sumário dos Testes

Início	26-05-2026
Fim	26-05-2026
Total de Vulnerabilidades	7
Severidade Crítica	2
Severidade Alta	0
Severidade Média	3
Severidade Baixa	1
Informacionais	1
Corrigidas	0
Em Reteste	0
Não Corrigidas	9

Vulnerabilidades por Severidade

CRÍTICA

[CONFIRMADO] Credenciais de administrador expostas no JavaScript público

Ativos afetados: 1 | Corrigidas: 0 | Reteste: 0 | Não corrigidas: 1

[CONFIRMADO] Bypass de autenticação via sessionStorage

Ativos afetados: 1 | Corrigidas: 0 | Reteste: 0 | Não corrigidas: 1

MÉDIA

[NÃO CORRIGIDO] Ausência de headers de segurança HTTP

Ativos afetados: 1 | Corrigidas: 0 | Reteste: 0 | Não corrigidas: 1

[NÃO CORRIGIDO] Painel administrativo embutido no bundle público da landing

Ativos afetados: 1 | Corrigidas: 0 | Reteste: 0 | Não corrigidas: 1

[NÃO CORRIGIDO] Armazenamento de contatos e campanhas em sessionStorage/localStorage

Ativos afetados: 1 | Corrigidas: 0 | Reteste: 0 | Não corrigidas: 1

BAIXA

[NÃO CORRIGIDO] Server Discloses Software Version (Netlify)

Ativos afetados: 1 | Corrigidas: 0 | Reteste: 0 | Não corrigidas: 1

INFO

[INFORMACIONAL] Painel administrativo acessível por URL direta (sem link na landing)

Ativos afetados: 1 | Corrigidas: 0 | Reteste: 0 | Não corrigidas: 1

Escopo do Projeto

camilaferrete.com.br

www.camilaferrete.com.br

https://camilaferrete.com.br/painel-campanhas/*

Histórico de Reteste

Nenhum reteste realizado.

VULNERABILIDADES

Credenciais de administrador expostas no JavaScript público

Severidade	CRÍTICA
Status	
CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N — Score: 9.1

Descrição

A aplicação web valida o acesso ao painel administrativo (/painel-campanhas) no código JavaScript entregue a qualquer visitante.

A credencial (senha) é hardcoded no bundle público servido em /assets/index-*.js, sem validação server-side.

Cenário de Ataque

Um atacante externo baixa o bundle JavaScript público, identifica trechos relacionados ao login do painel e extrai a credencial.

Com a credencial, o atacante acessa funcionalidades administrativas (ex.: contatos e templates).

Recomendação

Remover imediatamente a lógica de validação de senha do frontend.

Implementar autenticação e autorização server-side (ex.: Netlify Identity, Supabase Auth, Cloudflare Access ou função serverless protegida).

Rotacionar/abolir a credencial atual, assumindo que está comprometida.

Tags

Web Application

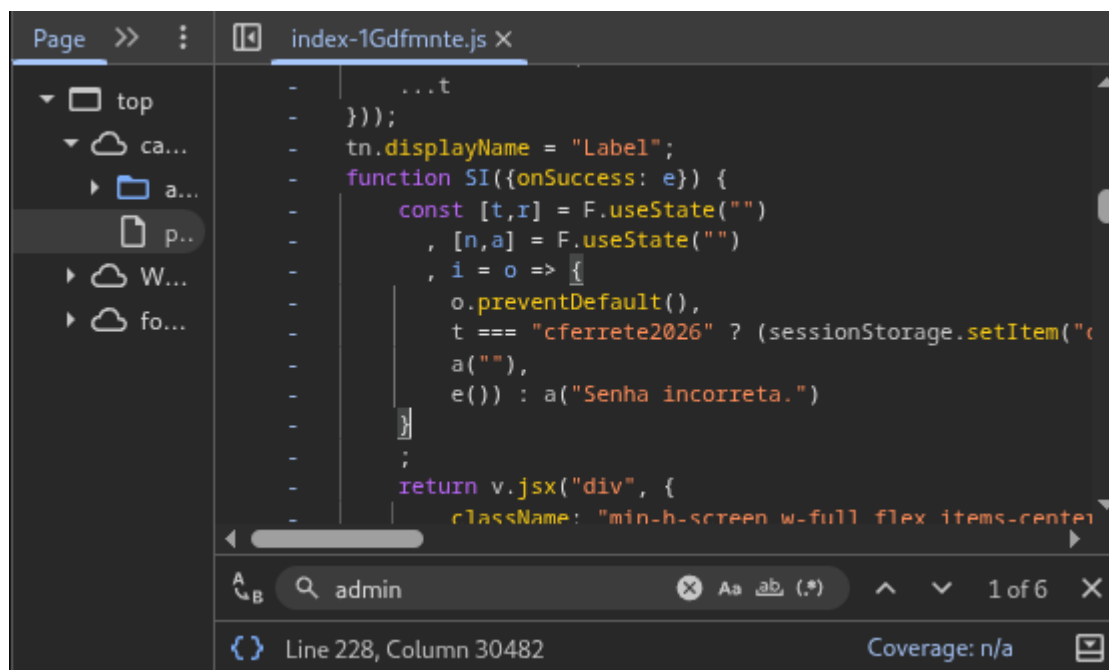
OWASP A07:2021 — Identification and Authentication Failures

CWE-798: Use of Hard-coded Credentials

Ativos Afetados

<https://camilaferrete.com.br/assets/index-1Gdfmnte.js>

Proof of Concept



```
...t
});
tn.displayName = "Label";
function SI({onSuccess: e}) {
  const [t,r] = F.useState("")
  , [n,a] = F.useState("")
  , i = o => {
    o.preventDefault(),
    t === "cferrete2026" ? (sessionStorage.setItem("cf-admin",
    a("")),
    e()) : a("Senha incorreta.")
  };
  return v.jsx("div", {
    className: "min-h-screen w-full flex items-center
```

Notas Adicionais

[CONFIRMADO] Não corrigida

Bypass de autenticação via sessionStorage

Severidade	CRÍTICA
Status	
CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N — Score: 9.1

Descrição

O painel administrativo considera o usuário autenticado quando `sessionStorage.getItem("cf-admin") === "ok"`.

Esse flag pode ser definido manualmente no Console do navegador, sem validação server-side.

Cenário de Ataque

O atacante abre /painel-campanhas em modo anônimo, define cf-admin via Console e recarrega a página.

O painel é exibido com o menu administrativo e funcionalidades associadas.

Recomendação

Não usar sessionStorage/localStorage como mecanismo de controle de acesso.
Proteger rotas sensíveis com autenticação real emitida e validada no servidor/edge.
Separar o deploy do painel da landing pública.

Tags

Web Application

OWASP A07:2021 — Identification and Authentication Failures

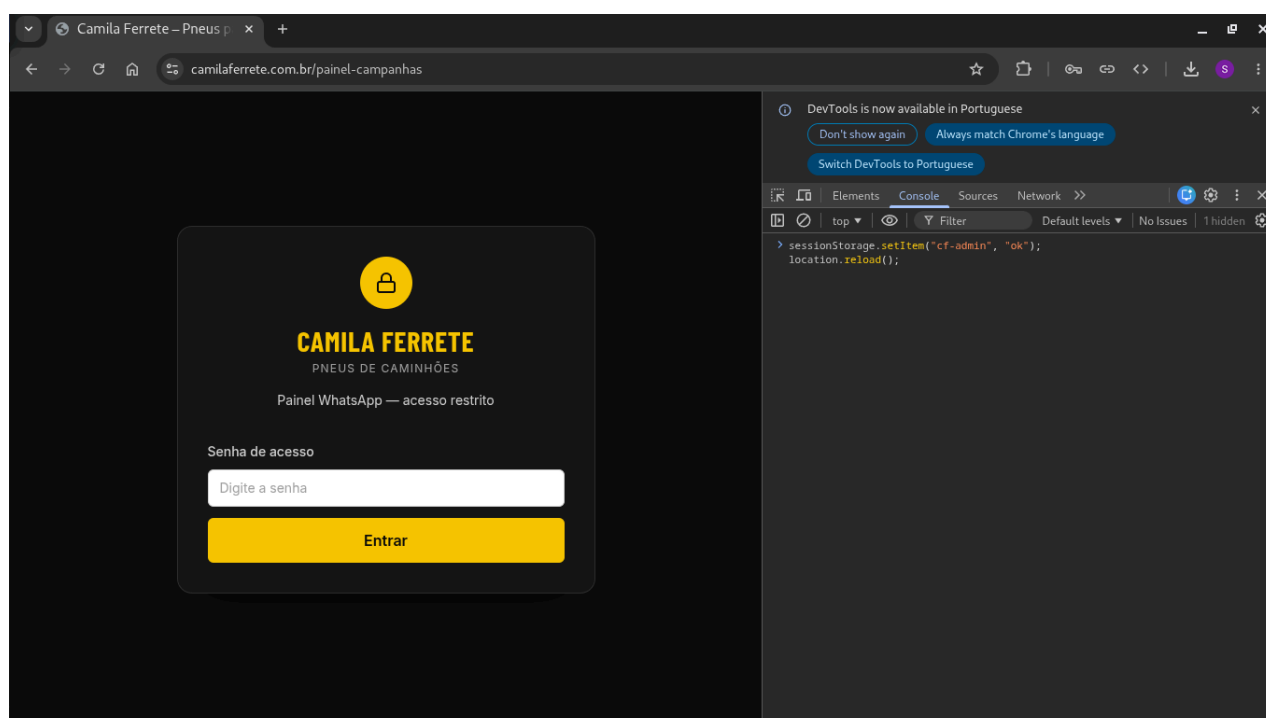
CWE-287: Improper Authentication

CWE-602: Client-Side Enforcement of Server-Side Security

Ativos Afetados

<https://camilaferrete.com.br/painel-campanhas/>*

Proof of Concept



Notas Adicionais

[CONFIRMADO] Não corrigida

Ausência de headers de segurança HTTP

Severidade	MÉDIA
Status	Não corrigida
CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N — Score: 5.4

Descrição

A resposta HTTP do site não inclui headers de segurança recomendados, como: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options e Referrer-Policy.

Apenas Strict-Transport-Security (HSTS) foi observado.

Cenário de Ataque

Em cenários específicos, a ausência de anti-clickjacking e CSP aumenta a probabilidade/impacto de ataques de injeção e abuso de conteúdo em iframes.

Recomendação

Configurar headers no Netlify (netlify.toml ou painel), com CSP e anti-clickjacking.

Garantir que a CSP permita apenas domínios necessários e definir frame-ancestors 'none'.

Tags

OWASP A02:2025 — Security Misconfiguration

CWE-693: Protection Mechanism Failure

Ativos Afetados

<https://camilaferrete.com.br/>

Proof of Concept

```
curl -sI "https://camilaferrete.com.br/" | \
  grep -iE
"content-security|x-frame|x-content-type|referrer-policy|strict-transport"
```

Notas Adicionais

Não corrigida

Painel administrativo embutido no bundle público da landing

Severidade	MÉDIA
Status	Não corrigida
CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N — Score: 5.3

Descrição

O painel administrativo (/painel-campanhas/*) não está apenas linkado, mas também embutido no mesmo bundle JavaScript público da landing.

Isso facilita a descoberta das rotas e da lógica de autenticação para qualquer visitante.

Cenário de Ataque

Um atacante inspeciona o bundle público, encontra rotas e combina com falhas de autenticação (ex.: bypass via sessionStorage).

Recomendação

Separar o painel em um deploy/host diferente (subdomínio ou outra aplicação).

Aplicar code-splitting e principalmente controle de acesso server-side/edge.

Tags

OWASP A02:2025 — Security Misconfiguration

Ativos Afetados

https://camilaferrete.com.br/painel-campanhas/*

Proof of Concept

Buscar no bundle por strings/rotas relacionadas a painel-campanhas e acessar diretamente:
<https://camilaferrete.com.br/painel-campanhas>

Notas Adicionais

Não corrigida

Armazenamento de contatos e campanhas em sessionStorage/localStorage

Severidade	MÉDIA
Status	Não corrigida
CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N — Score: 6.5

Descrição

Dados gerados/importados no painel são persistidos no navegador em chaves como cf-contatos, cf-templates (sessionStorage) e cf-campanhas (localStorage).

Esse armazenamento expõe dados a qualquer script executado no contexto da página e aumenta o impacto de qualquer XSS futuro.

Cenário de Ataque

Após obter acesso ao painel (por falhas de autenticação) ou em caso de comprometimento do navegador, um atacante acessa os dados diretamente via DevTools → Application.

Recomendação

Persistir dados sensíveis no backend autenticado.

Aplicar criptografia em repouso, controles de acesso e (quando aplicável) RLS.

Evitar armazenar PII em localStorage/sessionStorage.

Tags

OWASP A02:2025 — Security Misconfiguration

CWE-922: Insecure Storage of Sensitive Information

Ativos Afetados

https://camilaferrete.com.br/painel-campanhas/*

Proof of Concept

- 1) Entrar no painel (via autenticação)
- 2) DevTools -> Application -> Session Storage e Local Storage
- 3) Localizar chaves cf-contatos, cf-templates, cf-campanhas

Notas Adicionais

Não corrigida

Server Discloses Software Version (Netlify)

Severidade	BAIXA
Status	Não corrigida
CVSS v3.1	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N — Score: 3.7

Descrição

O servidor anuncia o header Server: Netlify na resposta HTTP.

Isso pode ajudar na fase de reconhecimento (fingerprinting), ainda que seja comum em plataformas gerenciadas.

Cenário de Ataque

Um atacante usa informações de plataforma para direcionar buscas por misconfigurations/vulnerabilidades relacionadas.

Recomendação

Priorizar hardening e headers de segurança.

Em plataformas gerenciadas, a ocultação total do header pode não ser possível; manter deploy e configurações corretas é o principal.

Tags

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Ativos Afetados

<https://camilaferrete.com.br/>

Proof of Concept

```
curl -sI "https://camilaferrete.com.br/" | grep -i server
```

Notas Adicionais

Não corrigida

Painel administrativo acessível por URL direta (sem link na landing)

Severidade	INFO
Status	Não corrigida
CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N — Score: 0

Descrição

O painel administrativo (/painel-campanhas) é acessível por navegação direta, sem nenhum link visível na landing page.

Embora não constitua vulnerabilidade por si só, a descoberta da rota é trivial via inspeção do bundle JS.

Cenário de Ataque

Um atacante descobre a rota e combina com outras falhas para obter acesso.

Recomendação

Proteger rotas sensíveis com autenticação server-side independente de obscuridade.

Tags

Security through obscurity

Ativos Afetados

<https://camilaferrete.com.br/painel-campanhas>

Proof of Concept

Acessar diretamente: <https://camilaferrete.com.br/painel-campanhas>

Notas Adicionais

Informacional

CONCLUSÃO

Após a análise em 26/05/2026, foram identificadas falhas que afetam diretamente o controle de acesso ao painel administrativo.

As vulnerabilidades críticas confirmadas (credenciais hardcoded no JavaScript público e bypass via sessionStorage) permitem acesso não autorizado ao painel, exigindo correção prioritária.

Além disso, recomenda-se aplicar hardening de headers e reduzir a exposição do painel e de dados sensíveis no armazenamento do navegador.

APÊNDICE: PLANO DE AÇÃO

Severidade	Vulnerabilidade	Ação	Impacto
CRÍTICA	Credenciais de admin expostas no JS público	Remover validação no frontend e implementar auth server-side	Reduzir risco de acesso não autorizado
CRÍTICA	Bypass de autenticação via sessionStorage	Proteger rotas sensíveis com validação no servidor/edge	Eliminar bypass por alteração de storage no cliente
MÉDIA	Ausência de headers de segurança HTTP	Adicionar CSP e headers anti-clickjacking	Reduzir superfície para ataques futuros
MÉDIA	Painel embutido no bundle público	Separar deploy do painel e aplicar auth real	Reduzir descoberta e exploração combinada
MÉDIA	Storage em sessionStorage/localStorage	Persistir dados no backend com controle de acesso	Reduzir exposição de PII
BAIXA	Server Discloses Software Version	Priorizar hardening e manter config corretas	Menor benefício para atacante

APÊNDICE: DEFINIÇÃO DOS NÍVEIS DE SEVERIDADE

CRÍTICA	Alta probabilidade de exploração nos próximos 12 meses.
ALTA	Atenção imediata.
MÉDIA	Recomenda-se planejamento e correção prioritária.
BAIXA	Mitigação recomendada a médio/longo prazo.
INFO	Itens informativos ou falsos positivos que auxiliam no contexto.